TLP:CLEAR Unrestricted public release.

CYBER THREAT INTELLIGENCE REPORT

Lazarus "Operation FlashHole" abuses South Korean security software, uses post-quantum encryption

From **Cybersecurity Brie ng** · 2026-10-27 to 2026-10-28 (US, Global, Industry; last 24 hours) and 2026-10-23 to 2026-10-28 (Indianapolis, State of Indiana) · Brie ng generated 2026-10-28

REPORT ID	VERSION	HANDLING
LIT-CTI-20261028-02	1.0 · 2026-10-28 08:07 EDT	TLP:CLEAR
BRIEFING SECTION	**ORIGINAL PUBLISHED**	**LAST UPDATE**
Global	2026-10-27	No update
CVES	**ANALYST**	
CVE-2026-68820 (CVSS 7.0)	Nick Sturgeon	

NATION-STATE | MEDIUM | ACTIVE CAMPAIGN (ESPIONAGE); CONFIRMED VICTIMS IN SOUTH KOREA | OVERALL CONFIDENCE: MODERATE

BOTTOM LINE UP FRONT

Kaspersky's Global Research and Analysis Team (GReAT) has published details of Operation FlashHole, a cyber-espionage campaign against South Korean organizations that it attributes to the North Korea-linked Lazarus Group. It presented the ndings at its Security Analyst Summit on 2026-10-21, and The Hacker News covered them on 2026-10-27 [S1] [S2] [S3] [S4]. The activity dates back to at least July 2025. At least three organizations are con rmed victims, in software, construction and wired-communication equipment manufacturing [S2] [S3]. Kaspersky says with medium-to-high con dence that the same actor ran FlashHole and the earlier Operation SyncHole. It also links the tooling to Lazarus's long-running job-themed Operation Dream Job [S2] [S4].

The intrusion starts with spear-phishing that links to fabricated resume, portfolio or interior-design sites hosted on GitHub Pages. At least one site used an apparently AI-generated pro le photo [S1] [S3]. These sites load external JavaScript and appear to trigger INISAFE CrossWeb EX V3 (3.4.1.2), a security plug-in that South Korean users must install for banking and government sites. That launches the legitimate Windows binary fsquirt.exe, which runs shellcode in memory [S2] [S4]. The chain then installs a series of loaders and backdoors. TechHub uses private GitHub repositories for command and control (C2). TouchHub and TouchShift provide persistence through a fake service and a side-loaded mscoree.dll. ClientHub is a new backdoor that talks over HTTPS to compromised Korean websites, and one variant uses the Dropbox API. LPEClient handles pro ling and delivers payloads. Cubridge is the nal modular backdoor

[S2]. LPEClient negotiates keys with ML-KEM-1024, a NIST post-quantum algorithm, and then decrypts payloads with Threefish. ClientHub encrypts its configuration with the SNOW 1.0 stream cipher [S2] [S4].

The briefing's CVE, CVE-2026-68820, is a use-after-free privilege-escalation flaw (CVSS 7.0) in the Windows Ancillary Function Driver for WinSock (AFD.sys). Microsoft fixed it on 2026-08-11, and it is listed as known-exploited [S5] [S7]. Check Point found it in a separate Lazarus Dream Job wave against defense and aerospace companies in Europe, Brazil and India. In that wave an ML-KEM-based loader delivered the FudModule rootkit [S6] [S7]. Kaspersky's FlashHole report mentions a zero-day linked to LPEClient but does not name the CVE or show its exploitation in the South Korean intrusions [S2]. The link between the CVE and FlashHole is therefore indirect.

Direct risk to Indiana organizations is low. The main exposures are companies with South Korean subsidiaries, partners or staff who use Korean banking and government plug-ins, and any organization targeted by job-themed lures. Defenders should take five steps. Confirm the August 2026 Windows cumulative update is installed everywhere, which closes CVE-2026-68820. Hunt for the file paths, MD5 hashes and C2 domains Kaspersky published. Alert when INISAFECrossWebEXSvc.exe spawns fsquirt.exe. Look for services that run ImeBroker.exe from System32\RasConv. Review egress to GitHub (API and Pages) and Dropbox from hosts that have no business need for it [S2] [S3]. Several things are still unknown: the exact CrossWeb EX flaw, the GitHub and Dropbox accounts, and the total number of victims.

Key judgments

VERY LIKELY · HIGH CONFIDENCE
Lazarus will very likely keep using South Korean financial and authentication plug-ins (CrossWeb EX, Cross EX, Innorix, AnySign4PC) as initial-access and execution vectors through 2027. The group has done this repeatedly since at least 2021, and these plug-ins remain mandatory for many Korean services. [S1] [S2] [S9]

LIKELY · MODERATE CONFIDENCE
Post-quantum key exchange (ML-KEM) is likely to spread across more Lazarus loaders. It is now documented in two separate toolsets (the Dream Job LPE loader and FlashHole's LPEClient), which makes payload recovery from network captures harder. It does not change the endpoint detection opportunities. [S2] [S3] [S7]

UNLIKELY · MODERATE CONFIDENCE
FlashHole infrastructure or tooling is unlikely to be seen against Indiana organizations without South Korean business ties within the next six months. The confirmed victims and the abused software are specific to Korea. [S2] [S3]

LIKELY · LOW CONFIDENCE
Kaspersky's suspicion of more victims is likely correct, and more victims will likely be disclosed. AhnLab, KISA or other vendors will likely publish further indicators, including the GitHub accounts and the specific CrossWeb EX weakness. [S2] [S4]

INDICATORS OF COMPROMISE

Almost all indicators come from Kaspersky's Securelist report of 2026-10-21 [S2] and cover activity from July 2025 into 2026. The C2 domains are compromised legitimate South Korean websites and may since have been cleaned, so treat hits as leads rather than verdicts. The FudModule hash and exploit file name come from Check Point's separate Dream Job report [S7] and relate to CVE-2026-68820, not directly to FlashHole.

Type	Indicator (defanged)	Context	Provenance	First seen	Source
md5	`ec84d6cb2ae7974767aedac246b50a3e`	TouchShift persistence DLL (mscoree.dll)	REPORTED		[S2]
md5	`a28cba214058fcae2883d8cffc883abd`	TouchShift persistence DLL (mscoree.dll)	REPORTED		[S2]
md5	`c105d6b16f544582772de0159f24c00a`	TouchShift persistence DLL (mscoree.dll)	REPORTED		[S2]
md5	`2f8475a90a25624ed02f1d18d4e6d65d`	TouchShift persistence DLL (mscoree.dll)	REPORTED		[S2]
md5	`676fabe30a28b53925fba98e34b35986`	TouchShift persistence DLL (mscoree.dll)	REPORTED		[S2]
md5	`b4a7eff35f048f06fb0a2d7631f23a7d`	TouchShift persistence DLL (mscoree.dll)	REPORTED		[S2]
md5	`ff07641dc56914dd90ee0bd7404d7ad7`	ClientHub loader (liblzma.dll)	REPORTED		[S2]
sha256	`3b6378df8442e63a6ed7317075913e4720847a510d95022d4a8347b2637c245d`	FudModule rootkit payload deployed after CVE-2026-68820 exploitation in Check Point's Dream Job reporting. This is a related Lazarus campaign, not FlashHole itself.	REPORTED	2026-07	[S7]
domain	`javadevhouse[.]co[.]kr`	Hosted the external JavaScript loaded by the GitHub Pages lure sites	REPORTED		[S2]
url	`hxxps[://]javadevhouse[.]co[.]kr/ajax/libs/jquery/1[.]7[.]3/jquery[.]min[.]js`	Fake jQuery script loaded by the lure pages as part of the initial chain	REPORTED		[S2]
domain	`pythonapischool[.]com`	Infrastructure used in the initial infection chain	REPORTED		[S2]
url	`hxxps[://]pythonapischool[.]com/api/detach`	Endpoint used in the initial infection chain	REPORTED		[S2]

Type	Indicator (defanged)	Context	Provenance	First seen	Source
domain	`cubedesign[.]co[.]kr`	Cubridge C2 (likely a compromised legitimate Korean site)	REPORTED		[S2]
url	`hxxps[://]cubedesign[.]co[.]kr/news`	Cubridge C2 URL	REPORTED		[S2]
url	`hxxps[://]cubedesign[.]co[.]kr/mobile/fashion`	Cubridge C2 URL	REPORTED		[S2]
domain	`fp-news[.]co[.]kr`	Cubridge C2 (likely a compromised legitimate Korean site)	REPORTED		[S2]
url	`hxxps[://]fp-news[.]co[.]kr/shop/cart`	Cubridge C2 URL	REPORTED		[S2]
domain	`k-wbc[.]co[.]kr`	ClientHub C2 (likely a compromised legitimate Korean site)	REPORTED		[S2]
url	`hxxps[://]k-wbc[.]co[.]kr/skin/social/social_view[.]php`	ClientHub C2 URL	REPORTED		[S2]
domain	`rcsh[.]co[.]kr`	ClientHub C2 (likely a compromised legitimate Korean site)	REPORTED		[S2]
url	`hxxps[://]rcsh[.]co[.]kr/modules/bbs/tiles/bbs_div/inputForm[.]php`	ClientHub C2 URL	REPORTED		[S2]
domain	`www[.]ksog[.]org`	ClientHub C2 (likely a compromised legitimate site)	REPORTED		[S2]
url	`hxxps[://]www[.]ksog[.]org/insert_file/handle[.]php`	ClientHub C2 URL	REPORTED		[S2]
filepath	`C:\Windows\System32\RasConv\ImeBroker.exe`	Copy of the legitimate printfilterpipelinesvc.exe that TouchHub registers as a service. It side-loads mscoree.dll.	REPORTED		[S2]

Type	Indicator (defanged)	Context	Provenance	First seen	Source
filepath	`C:\Windows\System32\RasConv\mscoree.dll`	TouchShift side-loaded DLL	REPORTED		[S2]
filepath	`C:\Windows\System32\RasConv\ActivationStore.dat`	Encrypted payload/data file next to TouchShift	REPORTED		[S2]
filepath	`C:\Windows\System32\DrvConh\mscoree.dll`	TouchShift side-loaded DLL (alternate directory)	REPORTED		[S2]
filepath	`C:\Windows\System32\DrvConh\ActivationStore.dat`	Encrypted payload/data file (alternate directory)	REPORTED		[S2]
filepath	`C:\ProgramData\RasConv\mscoree.dll`	TouchShift DLL location	REPORTED		[S2]
filepath	`C:\ProgramData\Apple\mscoree.dll`	TouchShift DLL location	REPORTED		[S2]
filepath	`C:\ProgramData\ssh\mscoree.dll`	TouchShift DLL location	REPORTED		[S2]
filepath	`C:\ProgramData\qorestor\mscoree.dll`	TouchShift DLL location	REPORTED		[S2]
filepath	`C:\ProgramData\Dell\mscoree.dll`	TouchShift DLL location	REPORTED		[S2]
filepath	`C:\ProgramData\Dell\Dell1.tmp`	Malware artifact listed in the IOC set	REPORTED		[S2]
filepath	`C:\ProgramData\Dell\Dell3.tmp`	Malware artifact listed in the IOC set	REPORTED		[S2]

Type	Indicator (defanged)	Context	Provenance	First seen	Source
filepath	`C:\ProgramData\Package.txt`	Malware artifact listed in the IOC set	REPORTED		[S2]
filepath	`C:\ProgramData\desktops.ini`	Malware artifact listed in the IOC set (note the misspelling of desktop.ini)	REPORTED		[S2]
filepath	`C:\Program Files\Common Files\System\msadc\msadc.inc`	ClientHub configuration file, encrypted with SNOW 1.0	REPORTED		[S2]
filepath	`C:\Windows\System32\drivers\monitor.sys`	A legitimate file used as the timestomping reference. Unexpected changes in nearby files' timestamps that match it are suspicious.	REPORTED		[S2]
command	`C:\Windows\System32\RasConv\ImeBroker.exe -TimeBroker`	Command line of the persistence service TouchHub creates. The service name is a random netsvcs name plus two letters, and the description is 'Microsoft Service'.	REPORTED		[S2]
command	`INISAFECrossWebEXSvc.exe -> fsquirt.exe`	Process lineage: the CrossWeb EX service launches fsquirt.exe (Bluetooth file transfer wizard), into which shellcode is injected or run. fsquirt.exe has no legitimate reason to be a child of this service.	REPORTED		[S1] [S2] [S4]
filename	`liblzma.dll`	ClientHub loader file name	REPORTED		[S2]
filename	`AdFinder.dll`	Plugin or module used by the toolset	REPORTED		[S2]
filename	`ActionModule.dll`	Cubridge action module (commands 23-41)	REPORTED		[S2]
filename	`FunctionModule.dll`	Cubridge function module (commands 42-79)	REPORTED		[S2]
filename	`Afd4Eop12_x64.dll`	CVE-2026-68820 AFD.sys exploit DLL that Check Point analyzed (Dream Job wave; compile time 2026-07-07)	REPORTED	2026-07-07	[S7]

Type	Indicator (defanged)	Context	Provenance	First seen	Source
registry	`HKLM\SOFTWARE\Microsoft\Windows NT\CurrentVersion\Svchost`	TouchHub reads the netsvcs group here to pick a believable service name	REPORTED		[S2]
registry	`HKLM\SYSTEM\CurrentControlSet\Services\<random>\ImagePath = C:\Windows\System32\RasConv\ImeBroker.exe -TimeBroker`	Inferred: creating the reported service writes this ImagePath under the Services key. The service name is random.	DERIVED		[S2]
http-request	`GET|POST|PATCH https://api.github.com/repos/<owner>/<repo>/issues`	TechHub uses GitHub Issues as its C2 (GET /issues?state=open|closed, POST /issues, PATCH /issues/<n>). Issue titles follow 1[ID]. The api.github.com host is inferred from the use of the GitHub API, and the repository names were not disclosed.	DERIVED		[S2]
http-request	`Cubridge C2 path pattern /<category word>/<article|list|story>/<8-digit number> with X-CSRF-Token and X-Requested-With headers`	Cubridge builds its C2 URLs from word lists (category words such as economy, opinion, politics) and a random number from 10000000 to 99999999	REPORTED		[S2]
domain	`api[.]dropboxapi[.]com`	Inferred: one ClientHub variant uses the Dropbox API with embedded credentials. This is the standard Dropbox API host, so watch for it only from unexpected processes. Account details were not disclosed.	DERIVED		[S2]
other	`KW4Ofw982CNJjxd51AVqkGAop`	Cubridge hard-coded C2 authentication token (useful for memory or YARA scanning)	REPORTED		[S2]
other	`x809G736iC3f8Wp8`	TouchShift hard-coded XOR key used to derive its AES key	REPORTED		[S2]

Type	Indicator (defanged)	Context	Provenance	First seen	Source
other	`xdkiTajAAxc3i/w[<881fnC!G*cb1Dit2sh.gAk/`	ZipCrypto archive password used by Cubridge commands 1, 42 and 64	REPORTED		[S2]

Indicators are defanged (hxxp, [.], [@]) so they cannot be clicked. "Reported" means stated in a source; "Derived" means inferred by the analyst from the source material and should be validated before blocking.

TACTICS, TECHNIQUES & PROCEDURES (TTPS)

Targets receive spear-phishing emails linking to tailored resume, portfolio or interior-design sites on GitHub Pages, some with AI-generated content. The sites load JavaScript from attacker infrastructure and, apparently by abusing INISAFE CrossWeb EX V3 3.4.1.2, cause INISAFECrossWebEXSvc.exe to launch fsquirt.exe, which runs shellcode in memory. The shellcode installs TechHub, a downloader that uses private GitHub repositories (the Issues API) as C2. TechHub fetches TouchHub. TouchHub copies printfilterpipelinesvc.exe to System32\RasConv\ImeBroker.exe, registers it as a randomly named netsvcs-style service, timestomps the new file, and side-loads TouchShift (mscoree.dll). TouchShift restarts TechHub in memory. TechHub then pulls ClientHub, a backdoor that uses SNOW 1.0-encrypted configuration and spoofed Chromium headers over HTTPS to compromised Korean websites (one variant uses Dropbox). ClientHub hands traffic to LPEClient, which negotiates ML-KEM-1024 keys and decrypts payloads with Threefish. LPEClient also disables a user-mode syscall-instrumentation hook to evade EDR, and then reflectively loads Cubridge. Cubridge is a modular backdoor with about 80 commands for reconnaissance, file theft, ZipCrypto archiving, injection, emulation of built-in Windows commands, and Chromium key and credential theft [S2] [S4]. In a related wave, the group used CVE-2026-68820 in AFD.sys to reach SYSTEM and deploy the FudModule rootkit [S6] [S7].

Threat actor

Lazarus Group · also tracked as Hidden Cobra, Diamond Sleet (Microsoft; for the Dream Job cluster), Operation Dream Job cluster

Attribution confidence: Moderate · **Motivation:** Espionage (intellectual property and strategic information from South Korean industry) · **Suspected origin:** North Korea (DPRK)

Kaspersky attributes FlashHole to Lazarus. It links FlashHole to SyncHole with medium-to-high confidence based on shared tools (TechHub/CLOUDBURST/NickelLoader, Cubridge/SIDESHOW/LightlessCan, TouchShift) and the Dream Job lure style [S2] [S3]. A COPPERHEDGE wave with a dark-web leak site (ULOSE) appeared around the same time, but Kaspersky treats it as a separate cluster [S1] [S2]. The alias list reflects common industry naming and was not taken from the cited sources.

MITRE ATT&CK mapping

Tactic	Technique	Procedure observed	Detection opportunity

Tactic	Technique	Procedure observed	Detection opportunity
Initial Access	T1566.002 Phishing: Spearphishing Link	Spear-phishing emails link to fake resume, portfolio and interior-design sites on GitHub Pages. [S1] [S2] [S3]	Email gateway and proxy logs for links to unfamiliar *.github.io pages sent to targeted staff.
Resource Development	T1583.006 Acquire Infrastructure: Web Services	GitHub accounts and repositories (three primary, one fallback) and Dropbox are used for lure hosting and C2. [S2]	Inventory which hosts and processes legitimately talk to api.github.com and the Dropbox API.
Resource Development	T1584.004 Compromise Infrastructure: Server	Compromised legitimate South Korean websites serve as Cubridge and ClientHub C2. [S2]	Proxy and DNS hits on the reported Korean domains.
Execution	T1203 Exploitation for Client Execution	The lure page appears to trigger INISAFE CrossWeb EX so that its service launches fsquirt.exe and runs shellcode. The exact flaw is not disclosed. [S2] [S3] [S4]	Alert on INISAFECrossWebEXSvc.exe spawning any process, especially fsquirt.exe.
Persistence	T1543.003 Create or Modify System Process: Windows Service	TouchHub registers ImeBroker.exe - TimeBroker as a service with a netsvcs-style random name and the description 'Microsoft Service'. [S2]	Event ID 7045 or 4697 for services whose ImagePath is under System32\RasConv or System32\DrvConh.
Persistence	T1574.002 Hijack Execution Flow: DLL Side-Loading	A renamed printfilterpipelinesvc.exe loads the malicious mscoree.dll (TouchShift, which exports LockClrVersion). [S2]	Image loads of mscoree.dll from outside the .NET framework and System32 root paths.
Defense Evasion	T1036.005 Masquerading: Match Legitimate Name or Location	Uses Windows-like names (ImeBroker.exe, mscoree.dll, msadc.inc, desktops.ini) in System32 and ProgramData. [S2]	Hash or signature checks for System32 binaries in non-standard subfolders.
Defense Evasion	T1070.006 Indicator Removal: Timestomp	Copies the timestamps of drivers\monitor.sys onto the dropped files. [S2]	Compare MFT $SI and $FN timestamps on the RasConv and DrvConh folders.
Defense Evasion	T1562.001 Impair Defenses: Disable or Modify Tools	LPEClient uses jscript9.dll HeapPageAllocator::ProtectPages to patch code and disable a user-mode syscall-instrumentation hook. [S2] [S3]	EDR tamper and telemetry-gap alerts; jscript9.dll loaded by unusual processes.
Defense Evasion	T1620 Reflective Code Loading	LPEClient and Cubridge load payloads reflectively in memory. [S2] [S4]	Memory scanning for unbacked executable regions and the hard-coded strings above.

Tactic	Technique	Procedure observed	Detection opportunity
Privilege Escalation	T1068 Exploitation for Privilege Escalation	In the related Dream Job wave, the AFD.sys use-after-free (CVE-2026-68820) is exploited to reach SYSTEM and deploy FudModule. [S6] [S7]	Patch compliance; kernel driver tampering and Smart App Control policy changes.
Command and Control	T1102.002 Web Service: Bidirectional Communication	TechHub uses GitHub Issues through the API, and one ClientHub variant uses the Dropbox API. [S2]	Non-browser processes calling api.github.com or the Dropbox API.
Command and Control	T1573.002 Encrypted Channel: Asymmetric Cryptography	ML-KEM-1024 key encapsulation, then Threefish, GOST and AES. Cubridge's handshake uses RSA and RC6. [S2] [S4]	Network payloads are opaque, so rely on endpoint and destination detection.
Credential Access	T1555.003 Credentials from Password Stores: Credentials from Web Browsers	Cubridge command 61 decrypts the Chromium AES key from Local State, and additional tools steal credentials and cookies. [S2] [S4]	Non-browser processes reading Chrome or Edge Local State and Login Data files.
Collection	T1560.002 Archive Collected Data: Archive via Library	ClientHub and Cubridge archive files with ZipCrypto, with no password or a hard-coded one. [S2]	Unexpected ZIP creation in temporary or ProgramData folders by non-archiver processes.
Defense Evasion	T1070.004 Indicator Removal: File Deletion	The ClientHub file-cleaner plugin overwrites files with NULL bytes, renames them randomly and deletes them. [S2]	Bursts of rename-then-delete activity by unsigned DLL hosts.

Detection & hunting

Queries are built from the reported behavior and indicators. They are untested; tune field names for your environment.

CrossWeb EX service spawning fsquirt.exe or other children `SIGMA`

```
title: INISAFE CrossWeb EX Service Spawning Suspicious Child
status: experimental
logsource:
  category: process_creation
  product: windows
detection:
  selection_parent:
    ParentImage|endswith: '\INISAFECrossWebEXSvc.exe'
  selection_child:
    Image|endswith:
      - '\fsquirt.exe'
      - '\cmd.exe'
      - '\powershell.exe'
      - '\rundll32.exe'
  condition: selection_parent and selection_child
level: high
tags:
  - attack.execution
  - attack.t1203
```

Built from the reported process chain. fsquirt.exe is the Bluetooth file transfer wizard and is rarely legitimate in this context.

FlashHole persistence: RasConv/DrvConh artifacts and fake service `KQL`

```
let paths = dynamic([@"\windows\system32\rasconv\", @"\windows\system32\drvconh\",
@"\programdata\rasconv\mscoree.dll", @"\programdata\apple\mscoree.dll",
@"\programdata\ssh\mscoree.dll", @"\programdata\qorestor\mscoree.dll",
@"\programdata\dell\mscoree.dll", @"\msadc\msadc.inc"]);
let md5s =
dynamic(["ec84d6cb2ae7974767aedac246b50a3e","a28cba214058fcae2883d8cffc883abd","c105d6b16f544582772de01
59f24c00a","2f8475a90a25624ed02f1d18d4e6d65d","676fabe30a28b53925fba98e34b35986","b4a7eff35f048f06fb0a2
d7631f23a7d","ff07641dc56914dd90ee0bd7404d7ad7"]);
union
 (DeviceFileEvents | where Timestamp > ago(90d) | where FolderPath has_any (paths) or MD5 in (md5s)),
 (DeviceImageLoadEvents | where Timestamp > ago(90d) | where FileName =~ "mscoree.dll" and FolderPath !
startswith @"C:\Windows\Microsoft.NET" and FolderPath !~ @"C:\Windows\System32\mscoree.dll" and
FolderPath !~ @"C:\Windows\SysWOW64\mscoree.dll"),
 (DeviceProcessEvents | where Timestamp > ago(90d) | where ProcessCommandLine has "ImeBroker.exe" and
ProcessCommandLine has "-TimeBroker")
| project Timestamp, DeviceName, ActionType, FolderPath, FileName, MD5, ProcessCommandLine,
InitiatingProcessFileName
```

Microsoft Defender for Endpoint advanced hunting. The mscoree.dll load filter may need tuning for legitimate .NET hosts.

Network contact with FlashHole C2 and staging domains `SPLUNK SPL`

```
index=proxy OR index=dns earliest=-90d
| eval host_lc=lower(coalesce(query, dest_host, url_domain, url))
| search host_lc IN ("*javadevhouse.co.kr*","*pythonapischool.com*","*cubedesign.co.kr*","*fp-news.co.kr*","*k-wbc.co.kr*","*rcsh.co.kr*","*ksog.org*")
| stats count min(_time) as first max(_time) as last values(src) as src by host_lc
| convert ctime(first) ctime(last)
```

The domains are compromised legitimate sites, so confirm hits by path (e.g., /skin/social/social_view.php, /insert_file/handle.php) before escalating.

Non-browser processes using GitHub API or Dropbox API `KQL`

```
DeviceNetworkEvents
| where Timestamp > ago(30d)
| where RemoteUrl has_any ("api.github.com", "api.dropboxapi.com", "content.dropboxapi.com")
| where InitiatingProcessFileName !in~ ("chrome.exe","msedge.exe","firefox.exe","git.exe","git-remote-https.exe","code.exe","github desktop.exe","dropbox.exe")
| summarize count(), make_set(RemoteUrl) by DeviceName, InitiatingProcessFileName, InitiatingProcessFolderPath
| order by count_ desc
```

A baseline hunt for the GitHub and Dropbox C2 patterns. Expect noise from developer tools and build agents; tune the allow-list.

REMEDIATION ACTIONS

Exposure

Product	Affected	Fixed in	CVE	CVSS	EPSS	CISA KEV	KEV due date
Microsoft Windows (AFD.sys, Ancillary Function Driver for WinSock)	Windows 10 1607/1809/21H2/22H2, Windows 11 23H2/24H2/25H2/26H1, Windows Server 2012/2012 R2/2016/2019/2022/2025 builds before the August 2026 updates (e.g., Win11 24H2 before 10.0.26100.9168, Server 2022 before 10.0.20348.5499)	August 2026 cumulative updates (2026-08-11) or later	CVE-2026-68820	7.0 (AV:L/AC:H/PR:L/UI:N/S:U/C:H/I:H/A:H)	0.00332 (26th percentile, 2026-10-27)	Yes (added 2026-08-11)	Not verified (KEV feed entry not retrieved)

Product	Affected	Fixed in	CVE	CVSS	EPSS	CISA KEV	KEV due date
Initech INISAFE CrossWeb EX V3	3.4.1.2 observed abused; the specific flaw and the full affected range are not disclosed	Unknown; no vendor advisory located	None assigned publicly	N/A	N/A	No	N/A

Immediate (0–24 hours)

- Run the IOC hunts (MD5s, file paths, the ImeBroker.exe -TimeBroker service, C2 domains) across EDR and proxy and DNS logs for the last 90 days, prioritizing clients with South Korean operations or staff. `SOC` [S2]
- Block the reported staging and C2 domains (javadevhouse.co.kr, pythonapischool.com, cubedesign.co.kr, fp-news.co.kr, k-wbc.co.kr, rcsh.co.kr, ksog.org) at DNS or the web proxy. Note that they are compromised legitimate sites. `IT OPS` [S2]
- Confirm the August 2026 (or later) Windows cumulative update is installed on all endpoints and servers to close CVE-2026-68820. `IT OPS` [S5] [S7]

Short term (1–7 days)

- Inventory endpoints with INISAFE CrossWeb EX, iniLINE Cross EX, Innorix Agent or AnySign4PC installed. Remove them where there is no business need, and update them to current vendor versions where they are required. `IT OPS` [S1] [S2] [S3]
- Deploy the Sigma and KQL detections for CrossWeb EX child processes, out-of-place mscoree.dll loads, and new services under System32\RasConv or System32\DrvConh. `SOC` [S2]
- Baseline which processes and hosts use the GitHub API and Dropbox API, and alert on new or unsigned ones. `SOC` [S2] [S3]
- Brief HR, recruiting and engineering staff about job-themed and portfolio lures, including AI-generated resumes and GitHub Pages sites. `LEADERSHIP` [S3] [S6]

Long term

- Apply application control (WDAC or AppLocker) to block unsigned DLLs and executables in System32 subfolders and ProgramData, and restrict local admin rights. `IT OPS` [S2] [S3]
- Isolate users who must run Korean banking or government plug-ins onto separate, restricted workstations or VDI rather than general-purpose endpoints. `LEADERSHIP` [S1] [S9]
- Adopt egress filtering that allows cloud storage and code-hosting services only for approved users and processes. `IT OPS` [S3]

Workarounds & compensating controls

- Where plug-ins cannot be removed, enable EDR memory scanning and alert on injection into fsquirt.exe and

printfilterpipelinesvc.exe copies. SOC [S2]
- Monitor for EDR telemetry gaps or tampering. LPEClient disables user-mode syscall hooks, so cross-check host telemetry against network logs. SOC [S2] [S3]

Actions marked with an owner: SOC = security operations, IT Ops = system and network administration, Leadership = risk and communications decisions.

SOURCES

[S1] The Hacker News: Lazarus abuses South Korean security software (Operation FlashHole)
Published 2026-10-27 · B2 Usually reliable, probably true
Briefing source; summarizes Kaspersky and adds historical context (SyncHole, AhnLab, KISA, Check Point).

[S2] Kaspersky Securelist (GReAT): Lazarus operation FlashHole
Published 2026-10-21 · A2 Completely reliable, probably true
Primary technical report and source of nearly all IOCs; single-vendor visibility.

[S3] Kaspersky: Kaspersky identifies new Lazarus APT campaign utilizing AI and post-quantum encryption
Published 2026-10-21 · A2 Completely reliable, probably true
Vendor press release with recommendations; partly promotional.

[S4] BleepingComputer: Lazarus hackers use post-quantum cryptography for malware delivery
Published 2026-10-21 · B2 Usually reliable, probably true
Independent summary consistent with Kaspersky.

[S5] CVE Program (MITRE CVE record): CVE-2026-68820
Published 2026-08-11 · A1 Completely reliable, confirmed by other sources
Affected and fixed builds, CVSS 7.0, CWE-416; CISA ADP shows KEV addition on 2026-08-11.

[S6] The Hacker News: Lazarus exploits Windows zero-day (CVE-2026-68820) in Dream Job campaign
Published 2026-08-12 · B2 Usually reliable, probably true
Covers the Check Point findings linking the CVE to Lazarus.

[S7] Check Point Research: Shattering the Dream: When a Job Offer Becomes a Zero-Day Attack
Published 2026-08-11 · A2 Completely reliable, probably true
Original CVE-2026-68820 exploitation research; ML-KEM-based LPE loader; FudModule hash.

[S8] FIRST EPSS API: EPSS score for CVE-2026-68820
Published 2026-10-27 · A1 Completely reliable, confirmed by other sources
EPSS 0.00332, 26th percentile.

[S9] SecurityOnline: Lazarus Operation FlashHole
Published 2026-10-21 · `C2` Fairly reliable, probably true
Adds that Kaspersky responded in January 2026 and gives tool alias cross-references; no new IOCs.

Grades use the Admiralty scale: letter = source reliability (A completely reliable to F cannot be judged), number = information credibility (1 confirmed to 6 cannot be judged).

MISCELLANEOUS

Timeline

Date	Event	Source
2021-07	Lazarus uses INISAFE CrossWeb EX to deliver the Racket downloader (DeathNote campaign; Q3 2021).	[S1]
2024-09	Earliest known use of post-quantum cryptography in Lazarus malware communications, per Kaspersky.	[S3]
2024-11	Operation SyncHole activity against South Korean industries begins.	[S1]
2025-07	Earliest FlashHole activity observed.	[S2] [S3]
2026-01	Kaspersky responds to FlashHole intrusions.	[S9]
2026-07	Joint KISA and vendor advisory on Lazarus exploiting financial security programs (AhnLab: Operation Double Barrel).	[S1]
2026-07-28	Check Point reports the AFD.sys zero-day to Microsoft.	[S7]
2026-08-11	Microsoft fixes CVE-2026-68820, Check Point publishes, and the CVE is added to CISA KEV.	[S5] [S7]
2026-10-21	Kaspersky publishes Operation FlashHole at SAS (Bali).	[S2] [S3] [S4]
2026-10-27	The Hacker News coverage (briefing source).	[S1]

Relevance to Indianapolis, Indiana & Lucidia IT clients

Direct exposure in Indianapolis and Indiana is limited. FlashHole targets South Korean organizations and depends on Korean-specific security plug-ins. The relevant groups are Indiana manufacturers, suppliers and joint ventures with South Korean parents or partners (for example, the automotive battery and electronics supply chains). University research groups and healthcare or software firms with staff who use Korean banking or government sites on corporate devices also fall in this group. Machines with CrossWeb EX or similar plug-ins installed should be treated as higher risk. The wider Lazarus Dream Job tradecraft (fake recruiters, resume and portfolio sites, GitHub-hosted payloads) hits US defense, aerospace and engineering targets, which matters for Indiana's defense industrial base and aerospace sector. CVE-2026-68820 is a privilege-escalation bug that

affects every Lucidia IT managed Windows client, so August 2026 patch compliance should be verified across the fleet. For small and mid-size clients, the practical steps are patch verification, a quick software inventory for Korean security plug-ins, and DNS blocking of the reported domains.

Intelligence gaps

- Kaspersky has not disclosed the exact CrossWeb EX weakness (or whether it is a vulnerability rather than feature abuse), and no Initech advisory, CVE or xed version was found.
- The GitHub account and repository names, the GitHub Pages lure URLs and the Dropbox account details were withheld.
- No IP addresses or SHA-256 hashes were published for FlashHole; only MD5s are available.
- It is unclear whether CVE-2026-68820 was used in the South Korean FlashHole intrusions or only in the Check Point Dream Job wave; the Securelist report does not name the CVE.
- The total victim count and any data theft impact are unknown; Kaspersky suspects more victims.
- Whether the COPPERHEDGE / ULOSE leak-site activity is operationally linked to FlashHole is unresolved.
- The CISA KEV due date for CVE-2026-68820 was not verified directly from the KEV feed.

Other notes

- Date discrepancy: the brie ng lists 2026-10-27 (The Hacker News), but Kaspersky's primary report and press release are dated 2026-10-21.
- Tool name cross-references: TechHub = CLOUDBURST (Mandiant) / NickelLoader (ESET); Cubridge = SIDESHOW (Mandiant) / LightlessCan (ESET); ClientHub is assessed as an advanced CookiePlus (medium-high con dence).
- Check Point calls the ML-KEM component in the August wave an 'LPE loader' and does not use the name LPEClient; The Hacker News connects the two.
- Kaspersky reports SNOW 1.0 as the rst observed use of that cipher in Lazarus malware.
- Kaspersky's claim of AI-assisted lure creation rests on an apparently AI-generated pro le photo and tailored sites; it is presented as suggestive rather than proven.

LIT-CTI-20261028-02 v1.0 · Generated 2026-10-28 08:07 EDT from public reporting. Drafted with AI assistance and reviewed by Nick Sturgeon. Verify indicators and actions before operational use. Summaries are in the analyst's own words.

TLP:CLEAR Unrestricted public release.